

Keamanan Informasi Presentasi PBL

Penerapan AAA dan Dashboard Logging Pada Aplikasi Bacarita – LIDM 2025



Adhiya R Fasya
G6401231068



M. Naufal Ramadhan
G6401231071



Anargya Isadhi M
G6401231118

Latar Belakang

Risiko Keamanan

Sistem ini memproses data sensitif seperti akun siswa, relasi orang tua-guru, rekaman bacaan, serta data eye-tracking.

Tanpa kontrol keamanan yang kuat, sistem rentan terhadap serangan **credential stuffing**, **penyalahgunaan hak akses**, **pencurian token**, serta **kebocoran data anak** beserta hasil evaluasinya.

Masalah keamanan yang diselesaikan:

✓ Mengubah *threat model* awal menjadi implementasi nyata **AAA (Authentication, Authorization, Accounting)**

✓ Menerapkan **kriptografi** untuk mengamankan data sensitif anak dan hasil evaluasi

✓ Melakukan **audit keamanan** secara langsung pada komponen codebase.



Gambaran Sistem



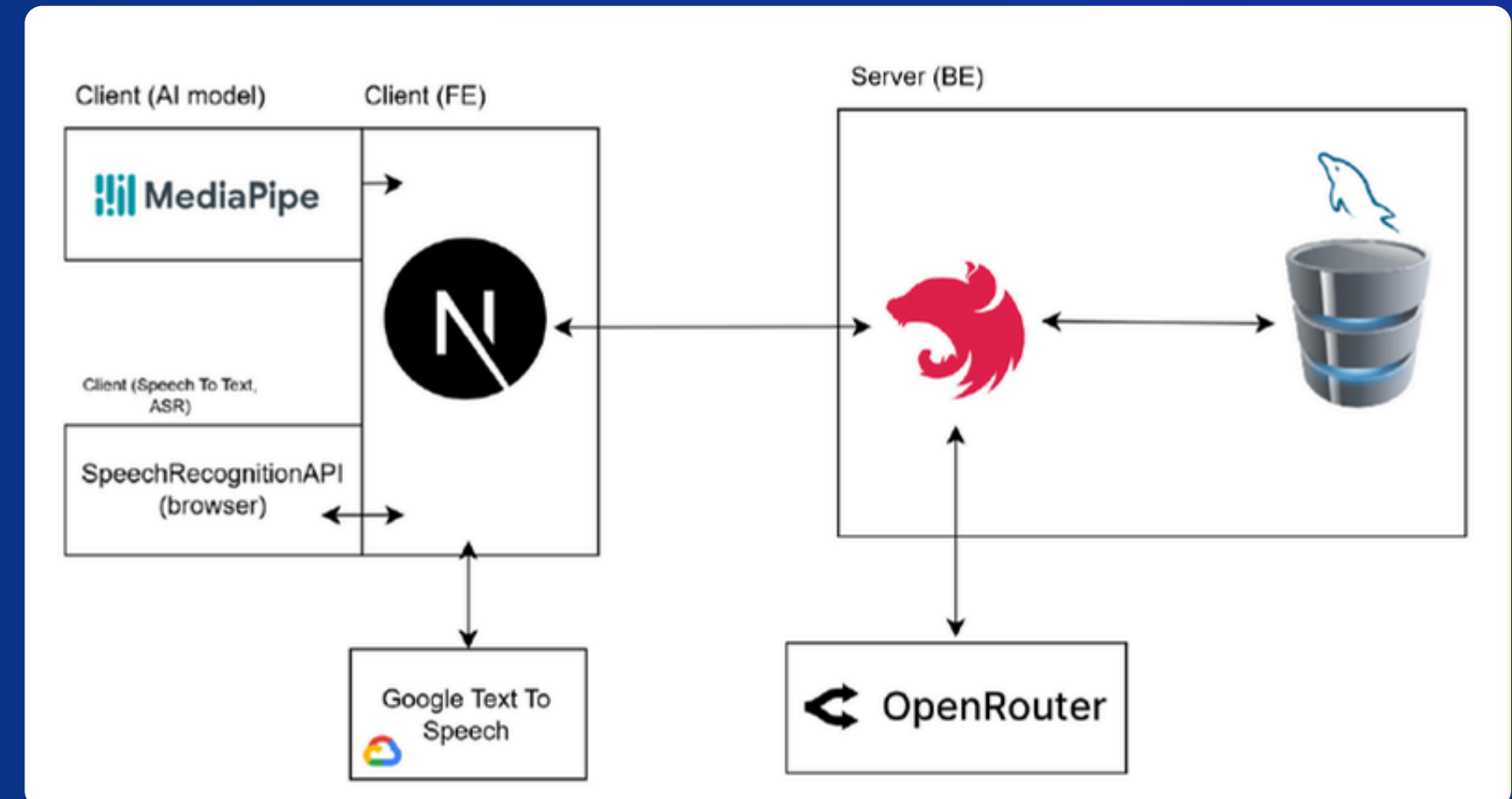
IPB University
— Bogor Indonesia —

AKTOR

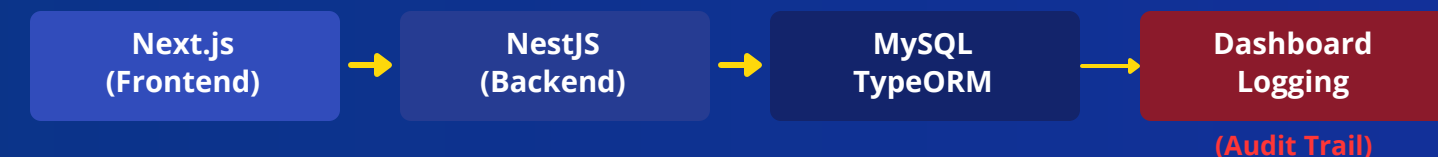
- **Siswa:** membaca dan tes
- **Guru:** memantau murid
- **Orang tua:** melihat perkembangan
- **Kurator:** approval cerita
- **Admin:** mengelola level/cerita + memantau sistem

FITUR UTAMA

- Login multi-role
- Dashboard per peran
- Level cerita
- Sesi membaca/STT (Speech-to-text)
- Eye-tracking
- Approval cerita
- Audit logging



Arsitektur Singkat



Dashboard logging **terpisah** dari aplikasi utama, khusus mencatat aktivitas user dan anomali untuk **audit keamanan**.

Threat Modeling

Aset & Ancaman

Aset yang Dilindungi

Akun pengguna, JWT session, data cerita/level, hasil test session, audit log, dan data kognitif anak (eye-tracking, rekaman bacaan).

Ancaman Utama

Brute force login, token theft (pencurian JWT), privilege escalation antar role, kebocoran data anak, dan tampering hasil evaluasi membaca.



Temuan Awal

Token Plain-text di Database

JWT token disimpan tanpa hashing, memungkinkan penyerang yang mengakses DB langsung menyamar sebagai user manapun.

Cookie Tidak Aman

Cookie tidak menggunakan flag HttpOnly dan Secure, rentan terhadap XSS dan session hijacking.

Tidak Ada Rate Limiting & Lockout

Endpoint login tidak memiliki pembatasan percobaan (rate limiting) maupun mekanisme lockout, membuka peluang brute force tanpa hambatan.

KESIMPULAN THREAT MODEL

Sistem memiliki kerentanan kritis pada manajemen token, konfigurasi cookie, dan absennya rate limiting. Ketiga temuan ini menjadi prioritas utama perbaikan karena langsung mengancam kerahasiaan data anak dan integritas hasil evaluasi.

Confidentiality



Token tidak boleh terekspos ke JavaScript; data sensitif hanya terlihat oleh role yang sah.

Integrity

Hasil test session dan aktivitas autentikasi harus dapat diverifikasi dan tidak mudah dimodifikasi diam-diam.



Availibility



Endpoint login harus tahan terhadap brute force sederhana; sistem tetap dapat digunakan oleh banyak role.

Authentication

Verifikasi identitas untuk teacher, student, parent, admin, curator.



Authorization



Pembatasan akses tegas berbasis role pada route backend dan middleware frontend.

Accountability

Setiap login berhasil, gagal, lockout, dan logout harus tercatat.



A. Data at Rest - AES-256-CBC

Tabel	Kolom	Alasan
students	fullName	PII anak (minor)
parents	fullName	PII orang tua
teachers	fullName, schoolName	PII guru / data institusi
admins	fullName	PII admin
curators	fullName, phoneNumber	PII kurator
test_sessions	passageAtTaken, descriptionAtTaken	Konten asesmen siswa

Plaintext : "Admin Bacarita 1"

Stored : bc6ed3b78b98256e769974f3708b5137:58c779673318cda9de9d253a...

Format : ivHex (32) : ciphertextHex

B. Data in Transit

- ▶ **HTTPS / TLS** wajib di seluruh endpoint
- ▶ **JWT** dikirim via Authorization: Bearer
- ▶ **X-Powered-By** dimatikan (info leakage)
- ▶ **Rate limit** 5 req / 60 detik per IP pada login

C. Key Management

Kunci	Algoritma	Ukuran	Penyimpanan
AES_SECRET_KEY	AES-256-CBC	256-bit	Env
JWT_SECRET	HMAC-SHA256	512-bit	Env
RSA Private Key	RSA-SHA256	2048-bit	Env
RSA Public Key	RSA-SHA256	2048-bit	Env

PASSWORD

bcrypt hash · one-way

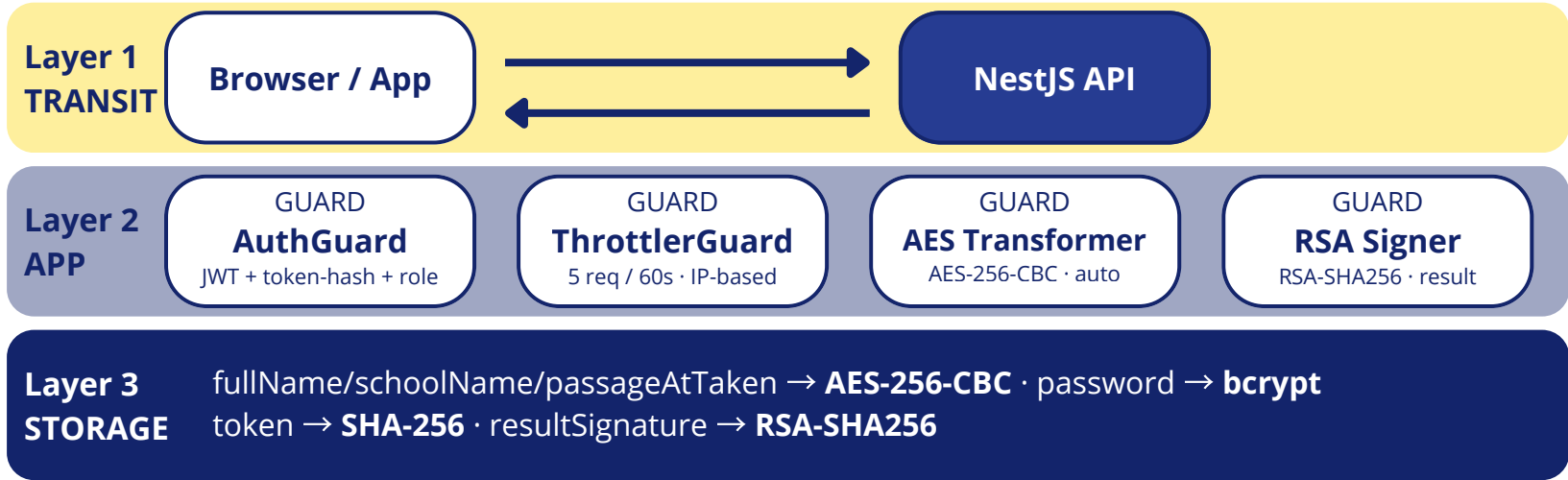
JWT-TOKEN

SHA-256 hash (revocable)

RESULT-SIGNATURE

RSA-SHA256 non-repudiation

Arsitektur Keamanan 3 Layer



```
mysql> SELECT id, fullName FROM admins;
+----+-----+
| id          | fullName |
+----+-----+
| 40b55497-8401-4b4b-890f-c7dd1a8e8b95 | 8e71e833a3c975a4d22f7204c206cb97:60bdc104dc32993f57b64f44f94ac7c93a4d98815d7ef92bd9bdf18005b08c7 |
+----+-----+
1 row in set (0.000 sec)

mysql> SELECT id, password FROM admins;
+----+-----+
| id          | password |
+----+-----+
| 40b55497-8401-4b4b-890f-c7dd1a8e8b95 | $2b$10$CA8HaRTuH3pQycXNxcSs0er0Gfh4e3nLDsm/.EKVP7/CR9Psbe4BW |
+----+-----+
1 row in set (0.000 sec)

mysql>
```


IPB University
— Bogor Indonesia —

Role	Endpoint
Student	POST /auth/students/login
Parent	POST /auth/parents/login
Teacher	POST /auth/teachers/login
Admin	POST /auth/admins/login
Curator	POST /auth/curators/login

REVOCATION

SHA-256 hash di logout

- \$2b** versi bcrypt
- \$10** cost factor (2^{10} rounds)
- 22 Char** salt unik 128-bit acak per user
- sisanya** hash result $\rightarrow$ `bcrypt.compare(input, hash)` $\rightarrow$ boolean

7 Cari user berdasarkan **username**

POST http://localhost:5002 /auth/admins/login

Params Body 1 Headers Cookies Auth

none form-data x-www-form-urlencoded JSON

Auto-generate Insert Dynamic Value

```
1 {
2   "username": "admin-bacarita-1",
3   "password": "adminbacaritavercel"
4 }
```

```
1 {
2   "success": true,
3   "statusCode": 200,
4   "message": "Login berhasil (admin)",
5   "data": {
6     "token":
7       "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6IjQwYjU1NDk3LTg0MDEtNGI0Yi00QxYThlOGI5NSIsImVtYWlsIjoiYWRtaW5AYWdmVyY2VsLmFwcCI6InVzZXJuYW1lIjoiYWRJpdGEtMSIsInJvbGU0IjoiJhZG1pbiIsIm1hdNjg4OSwiZXhwIjoxNzgxMDMxNjg5fQ.fDRlAzCymcf6DW_o3CORJ9A7Hz-z0QBjYk7
8   }
9 }
```

Implementasi Authorization

A. RBAC - 6 Role

Role	Boleh Akses	Dibatasi
ADMIN	Semua audit log, kelola semua user	Tanpa pembatasan signifikan
CURATOR	Kelola cerita & konten	Audit log, data user
TEACHER	Data siswa sendiri, buat level	Data guru lain, audit log
STUDENT	Test session milik sendiri	Data siswa lain, manajemen
PARENT	Data anak yang terhubung	Data anak orang tua lain
ANY	GET /auth/me (profil sendiri)	-

```
@UseGuards(AuthGuard)
@Auth(AuthRole.ADMIN)
@Get('audit-logs')
getAuditLogs() { /* return ... */ }
```

B. AuthGuard — 3 Lapis Validasi Request

1 Client kirim **username + password**

LAPIS 1 · AUTHENTICATION
Verifikasi JWT Signature
jwt.verify(token, JWT_SECRET)

Invalid
401 Unauthorized

LAPIS 2 · TOKEN REVOCATION
SHA-256(token) cocok di DB?
cek hash → token aktif / revoked

Revoked
401 Unauthorized

LAPIS 3 · AUTHORIZATION
Role JWT == @Auth(role)?
RBAC check terhadap dekorator

Role Salah
403 Forbidden

Controller dieksekusi · 200 OK

Body 401 · 27ms · 311B Failed

Pretty JSON utf8

```
1 {
2   "success": false,
3   "statusCode": 401,
4   "error": "Unauthorized"
5 }
```

Body 403 · 5ms · 305B Failed

Pretty JSON utf8

```
1 {
2   "success": false,
3   "statusCode": 403,
4   "error": "Forbidden"
5 }
```


Implementasi Accounting

A. AUTH and API Flow

• AUTH FLOW (login / logout)



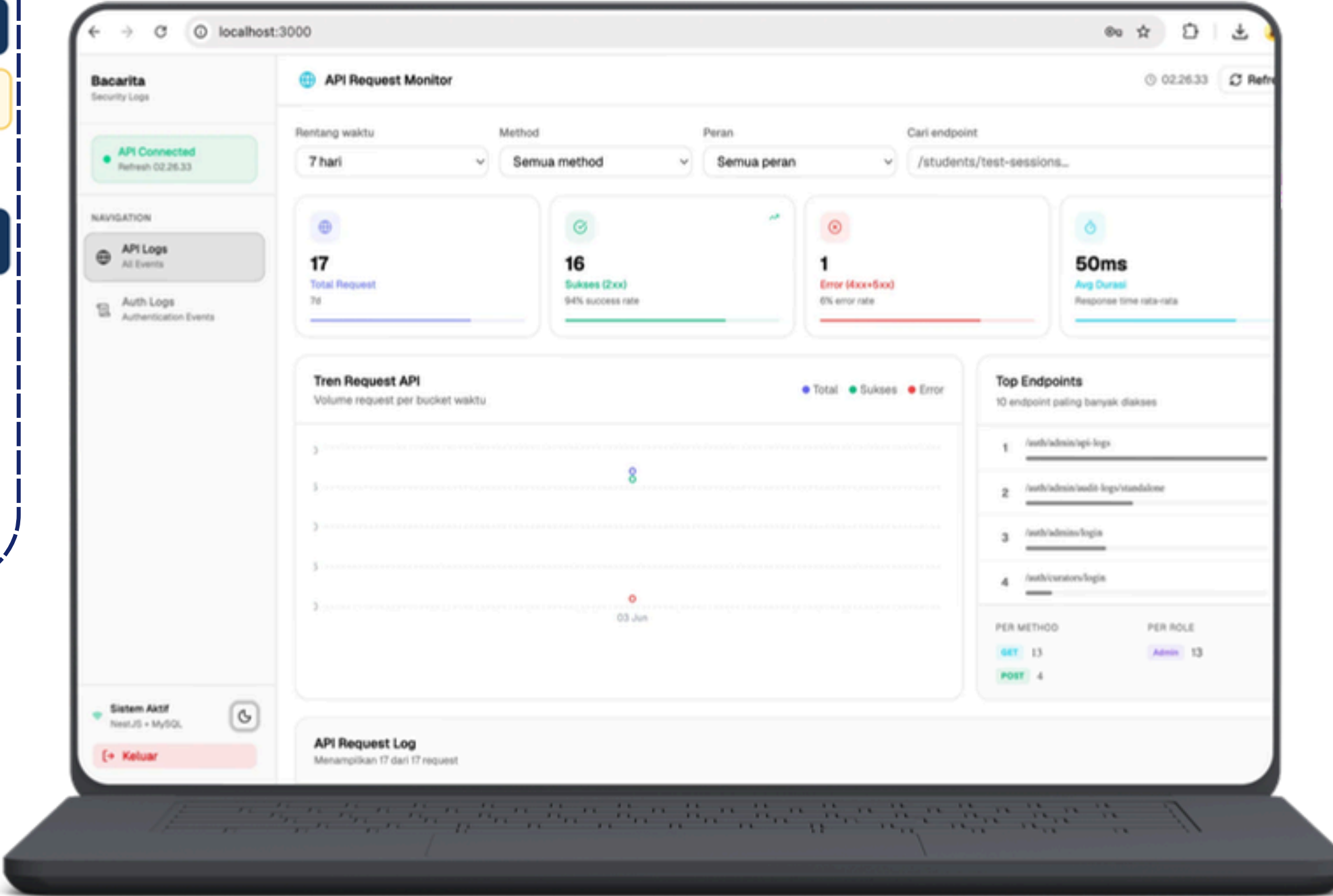
• API FLOW (semua endpoint)



Contoh: api_audit_logs.txt

```
{ "timestamp": "2026-06-02T10:05:58.118Z", "event": "LOGIN_OK", "userId": "874312dc-efe1-4516-b734-8a5f6eb12c35", "role": "admin", "ip": "::1" }
{ "timestamp": "2026-06-02T10:14:17.736Z", "event": "LOGIN_OK", "userId": "874312dc-efe1-4516-b734-8a5f6eb12c35", "role": "admin", "ip": "::1" }
{ "timestamp": "2026-06-02T10:31:16.363Z", "event": "LOGIN_FAIL", "userId": null, "role": "admin", "ip": "::1" }
{ "timestamp": "2026-06-02T16:40:47.952Z", "event": "LOGIN_OK", "userId": "874312dc-efe1-4516-b734-8a5f6eb12c35", "role": "admin", "ip": "::1" }
{ "timestamp": "2026-06-02T19:01:29.799Z", "event": "LOGIN_OK", "userId": "40b55497-8401-4b4b-890f-c7dd1a8e8b95", "role": "admin", "ip": "::1" }
{ "timestamp": "2026-06-02T19:20:49.972Z", "event": "LOGIN_FAIL", "userId": null, "role": "admin", "ip": "::1" }
```

API Request Log							
Menampilkan 19 dari 19 request							
Timestamp	Method	Endpoint	Status	Durasi	Role	User ID	IP
03 Jun 26 02:27:03	GET	/auth/admin/api-logs	200	5ms	Admin	40b55497-8401-4b4b-890f-c7dd1a8e8b95	::1
03 Jun 26 02:26:33	GET	/auth/admin/api-logs	200	37ms	Admin	40b55497-8401-4b4b-890f-c7dd1a8e8b95	::1
03 Jun 26 02:26:04	GET	/auth/admin/api-logs	200	9ms	Admin	40b55497-8401-4b4b-890f-c7dd1a8e8b95	::1
03 Jun 26 02:25:34	GET	/auth/admin/api-logs	200	16ms	Admin	40b55497-8401-4b4b-890f-c7dd1a8e8b95	::1



Implementasi Kriptografi

ALGORITMA APA?

Enkripsi Data (AES-256-CBC)

- data pengguna sensitif
- enkripsi simetris dengan performa tinggi
- standar industri

Digital Signature (RSA-SHA256)

- integritas data
- memastikan keaslian hasil
- perubahan = verifikasi gagal

AES

Bcrypt

Hashing Password

DB menyimpan hash $\neq$ plaintext, salt, anti brute-force

Hashing Token (JWT)

- digest satu arah
- token tidak disimpan dalam bentuk asli
- ringan dan cepat untuk verifikasi

SHA-256

Sertifikat Web

- mengenkripsi data saat transmisi
- mencegah penyadapan jaringan
- mendukung autentikasi server

RSA

HTTPS/
TLS

Hasil Pengujian

```
Test Suites: 9 passed, 9 total
Tests:      59 passed, 59 total
Snapshots:  0 total
Time:       3.358 s
Ran all test suites.
```



Functional Testing

- Menguji logika inti backend seperti story, level, level progress, test session, dan STT word result
- Menguji konsistensi response dan error handling backend
- Hasil: fungsi utama sistem berjalan sesuai perilaku yang diharapkan

Security Testing

- Menguji AuthGuard untuk kasus 401, 403, token invalid, dan token revoked
- Menguji digital signature RSA-SHA256 untuk payload valid, payload termodifikasi, dan signature palsu
- Hasil: kontrol authentication, authorization, dan integrity berjalan dengan benar

Integration Testing

- Tersedia E2E spec untuk auth, dashboard, registrasi guru, registrasi siswa, dan sesi tes siswa
- Menguji keterhubungan antar modul backend pada alur utama
- Hasil: skenario integrasi utama sudah tercakup pada level test spec



Analisis Performa

Sebelum Implementasi

- Login hanya memverifikasi kredensial
- Belum ada rate limiting dan account
- Token lebih berisiko jika bocor
- Audit aktivitas keamanan masih lemah

Setelah Implementasi

- Token di-hash dengan SHA-256 sebelum disimpan di database
- Login dibatasi dengan rate limiting
- Ada account lockout setelah gagal login berulang
- Ada audit log database dan digital signature hasil tes

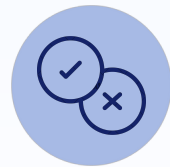
DAMPAKNYA?

Ada tambahan proses pada login dan validasi request, operasi tulis ke database untuk audit log, proses signing pada hasil akhir sesi tes.

Overhead meningkat sedikit, tetapi risiko keamanan turun signifikan

Kesimpulan

3 TOPIK KESIMPULAN



Pencapaian

Authentication, Authorization, dan Accountability (AAA) berhasil diimplementasikan

Password dan token diamankan menggunakan mekanisme hashing

Audit log pada dashboard berhasil diterapkan untuk meningkatkan akuntabilitas

Digital signature diterapkan untuk menjaga integritas hasil evaluasi



Keterbatasan

Belum dilakukan benchmark performa formal

Pengujian E2E masih dapat diperluas

Proteksi data sensitif pengguna masih dapat ditingkatkan



Pengembangan

Rotasi dan manajemen kunci RSA

Enkripsi data at-rest yang lebih luas

Pengujian integrasi dan keamanan yang lebih komprehensif

Logging dashboard yang memantau lebih banyak sisi pada sistem



IPB University
— Bogor Indonesia —

Inspiring Innovation with Integrity
in Agriculture, Ocean and Biosciences for a Sustainable World